Security Operations – Firewall & Nmap Analysis

Corso: Cybersecurity Analyst
Modulo: W18D1 (Pratica)
Studente:Emanuele cestari

Obiettivo

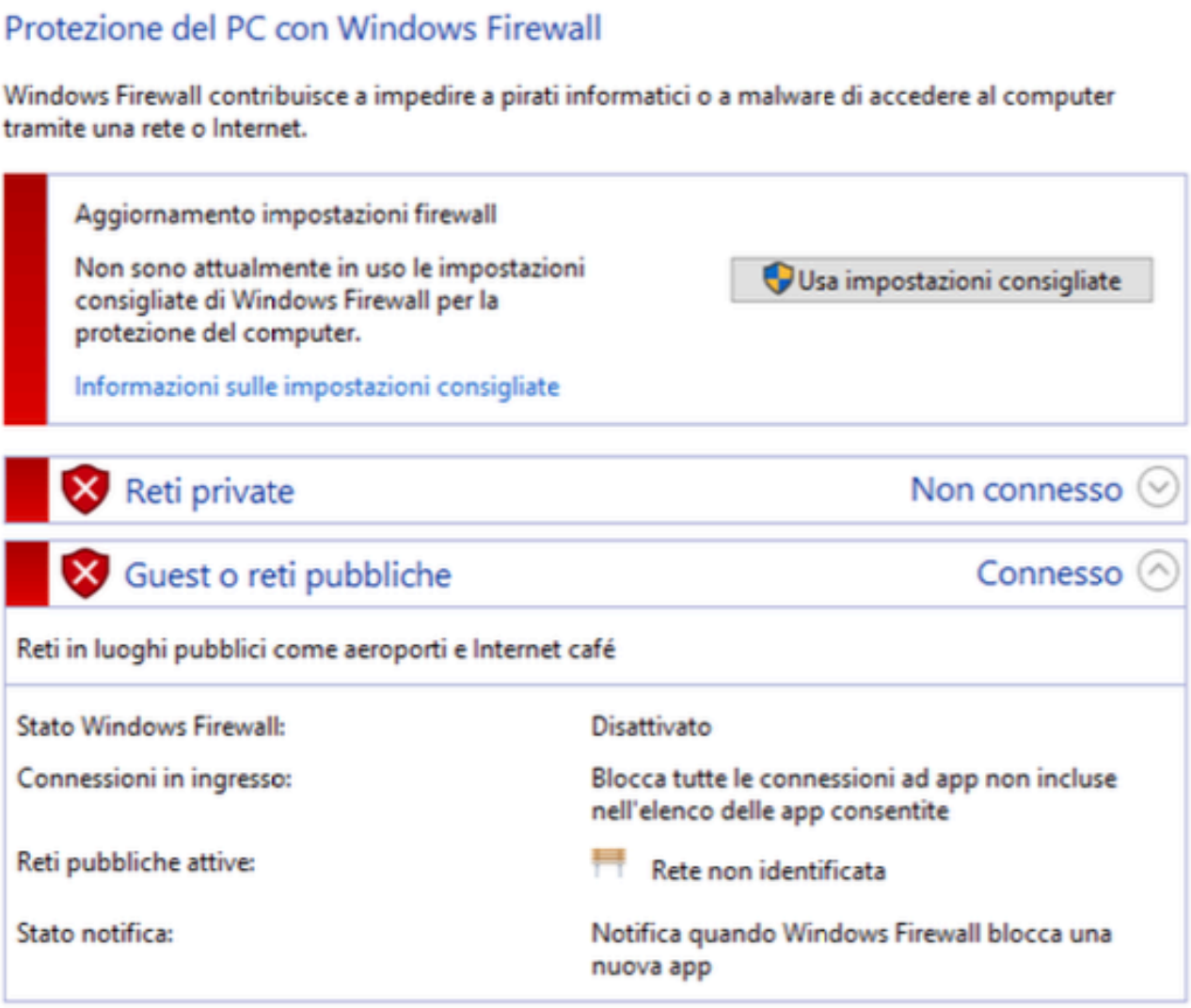
Valutare l'influenza del firewall su una scansione Nmap mettendo a confronto tre scenari: configurazione predefinita, configurazione standard e configurazione più stringente.

Ambiente di laboratorio

- Kali Linux (Attacker)
- Windows 10 (Target)
- Rete: 192.168.50.0/24
- Tool: Nmap (-sV)

Firewall DISATTIVATO (Default)

Il firewall sulla macchina Windows è stato disabilitato. È stata quindi eseguita una scansione Nmap con rilevamento dei servizi, salvando il risultato in un file di testo: nmap -sV 192.168.50.102 -oN scan_no_firewall.txt



Risultato:
Numerose porte aperte

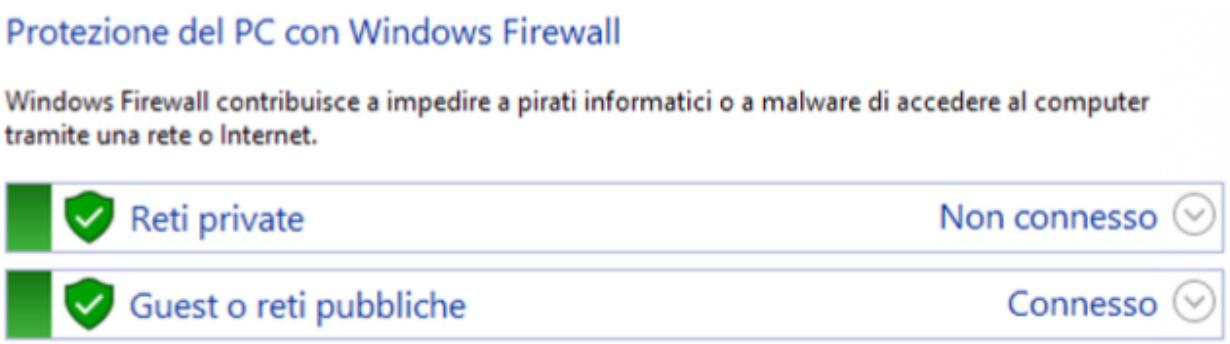
```
┌──(kali㉿kali)-[~/Desktop]
└─$ cat scan_no_firewall.txt
# Nmap 7.98 scan initiated Tue Apr 21 09:23:02 2026 as: /usr/lib/nmap/nmap --privileged -sV
 -oN scan_no_firewall.txt 192.168.50.102
Nmap scan report for 192.168.50.102
Host is up (0.0029s latency).
Not shown: 982 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
7/tcp    open  echo
9/tcp    open  discard?
13/tcp   open  daytime       Microsoft Windows International daytime
17/tcp   open  qotd          Windows qotd (English)
19/tcp   open  chargen
80/tcp   open  http          Microsoft IIS httpd 10.0
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds  Microsoft Windows 7 - 10 microsoft-ds (workgroup: WORKGROUP)
1801/tcp open  msmq?
2103/tcp open  msrpc         Microsoft Windows RPC
2105/tcp open  msrpc         Microsoft Windows RPC
2107/tcp open  msrpc         Microsoft Windows RPC
3389/tcp open  ms-wbt-server Microsoft Terminal Services
5432/tcp open  postgresql?
8009/tcp open  ajp13         Apache Jserv (Protocol v1.3)
8080/tcp open  http          Apache Tomcat/Coyote JSP engine 1.1
8443/tcp open  https-alt?
MAC Address: 0A:CF:10:76:09:9B (Unknown)
Service Info: Host: DESKTOP-9K1O4BT; OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit
/ .
# Nmap done at Tue Apr 21 09:26:13 2026 -- 1 IP address (1 host up) scanned in 190.68 secon
ds
```

Servizi visibili (RPC, SMB, RDP, HTTP),Alta superficie di attacco

Attivazione Firewall

Il firewall è attivo con configurazione predefinita, il che potrebbe causare il blocco dei pacchetti ICMP. Ho eseguito una scansione con nmap -sV 192.168.50.102 -Pn, ottenendo i seguenti risultati: alcune porte risultano aperte, mentre altre sono filtrate. L'uso dell'opzione -Pn è stato necessario a causa della configurazione del firewall.



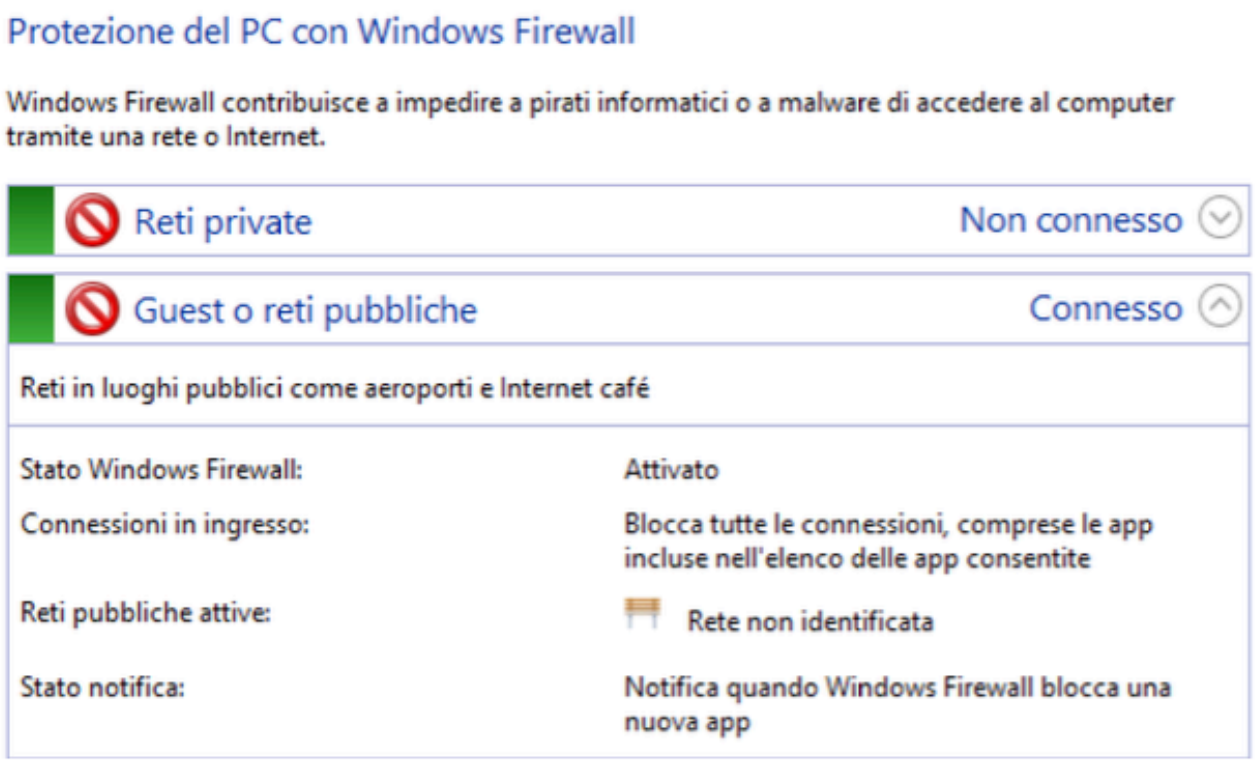
Mettiamo in azione il comando -Pn

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -sV 192.168.50.102 -Pn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 10:19 -0500
Nmap scan report for 192.168.50.102
Host is up (0.0041s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
80/tcp   open  http          Microsoft IIS httpd 10.0
135/tcp  open  msrpc         Microsoft Windows RPC
1801/tcp open  msmq?
2103/tcp open  msrpc         Microsoft Windows RPC
2105/tcp open  msrpc         Microsoft Windows RPC
2107/tcp open  msrpc         Microsoft Windows RPC
3389/tcp open  ms-wbt-server Microsoft Terminal Services
8443/tcp open  https-alt?
MAC Address: 0A:CF:10:76:09:9B (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 113.74 seconds
```

Firewall ATTIVO

Firewall configurato per bloccare tutte le connessioni in ingresso.
Scansione: nmap -sV 192.168.50.102



Scan con blocco totale
Risultato: tutte le porte FILTERED
Nessun servizio raggiungibile e sistema non numerabile

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -sV 192.168.50.102 -oN scan_firewall_on.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 09:39 -0500
Nmap scan report for 192.168.50.102
Host is up (0.00060s latency).
All 1000 scanned ports on 192.168.50.102 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 0A:CF:10:76:09:9B (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit
/ .
Nmap done: 1 IP address (1 host up) scanned in 26.17 seconds
```

Analisi Tecnica

Con il firewall disattivato, il sistema espone diversi servizi ed è facilmente enumerabile. Attivando il firewall con policy di blocco totale inbound, il traffico viene completamente filtrato. Nmap non riceve risposta (no-response), classificando tutte le porte come FILTERED. Questo comportamento riduce significativamente la visibilità del sistema e le possibilità di attacco. Il firewall può operare a vari livelli di restrizione, influenzando direttamente la capacità di un attaccante di enumerare il sistema.

Confronto con Approccio Didattico

Nella soluzione proposta durante il corso, viene mostrato un approccio più granulare in cui il firewall blocca principalmente il traffico ICMP (ping), rendendo necessario l'utilizzo dello switch -Pn per bypassare la fase di host discovery. In questo scenario:

Alcune porte risultano ancora OPEN

Altre risultano FILTERED

il sistema è parzialmente visibile

Nel presente laboratorio, è stata invece applicata una configurazione più restrittiva, con blocco completo delle connessioni in ingresso. Questo ha comportato che tutte le porte risultassero nello stato FILTERED, impedendo completamente l'enumerazione dei servizi. Tale configurazione rappresenta uno scenario più realistico in ambienti enterprise, dove l'obiettivo è ridurre al minimo la superficie di attacco e limitare l'esposizione del sistema.

Conclusione

L'attivazione del firewall è una misura preventiva fondamentale. Una configurazione restrittiva consente non solo di bloccare accessi non autorizzati, ma anche di rendere il sistema non visibile agli strumenti di scanning. Questo dimostra l'importanza del filtering a livello di rete nelle strategie di difesa moderne.

SEZIONE FACOLTATIVA

OBBIETTIVO:

Analizzare i log di Windows durante una scansione Nmap per identificare tentativi di connessione, attività bloccate dal firewall e indicatori di scanning.

Log analizzati

1. Firewall Log (pfirewall.log)
2. Event Viewer → Security
3. Event Viewer → System
4. Windows Firewall with Advanced Security

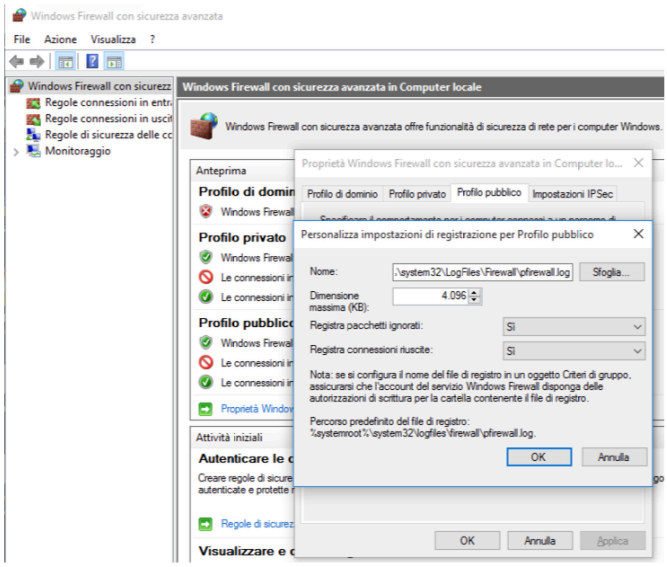
Abilitazione logging Firewall

Windows Firewall → Impostazioni avanzate → Monitoring → Logging

Attivare:

- Log dropped packets
- Log successful connections

Impostazioni logging attivo



SCANSIONE CON NMAP
Eseguire scansione da Kali:
nmap -sV 192.168.50.102
Terminale Kali con scan

```
┌──(kali㉿kali)-[~/Desktop]
└─$ nmap -sV 192.168.50.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 10:50 -0500
Nmap scan report for 192.168.50.102
Host is up (0.0024s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT     STATE SERVICE       VERSION
80/tcp   open  http          Microsoft IIS httpd 10.0
135/tcp  open  msrpc         Microsoft Windows RPC
1801/tcp open  msmq?
2103/tcp open  msrpc         Microsoft Windows RPC
2105/tcp open  msrpc         Microsoft Windows RPC
2107/tcp open  msrpc         Microsoft Windows RPC
3389/tcp open  ms-wbt-server Microsoft Terminal Services
8443/tcp open  https-alt?
MAC Address: 0A:CF:10:76:09:9B (Unknown)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 113.66 seconds
```

Analisi Firewall Log

Aprire il file di log pfirewall.log in C:\Windows\System32\LogFiles\Firewall. Verificare le connessioni bloccate (DROP), l'IP sorgente (Kali) e le porte target. Cercare i log con DROP e l'IP dell'attacker

pfirewall - Blocco note
File Modifica Formato Visualizza ?

```
#Version: 1.5
#Software: Microsoft Windows Firewall
#Time Format: Local
#Fields: date time action protocol src-ip dst-ip src-port dst-port size tcpflags tcpsyn tcpack tcpwin icmptype icmpcode info path


2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52856 8080 44 S 1045314796 0 1024 - - - RECEIVE
2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52854 139 44 S 1045183726 0 1024 - - - RECEIVE
2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52854 445 44 S 1045183726 0 1024 - - - RECEIVE
2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52856 139 44 S 1045314796 0 1024 - - - RECEIVE
2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52856 445 44 S 1045314796 0 1024 - - - RECEIVE
2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52854 7 44 S 1045183726 0 1024 - - - RECEIVE
2026-04-21 17:51:02 DROP TCP 192.168.50.100 192.168.50.102 52856 7 44 S 1045314796 0 1024 - - - RECEIVE
2026-04-21 17:51:03 DROP TCP 192.168.50.100 192.168.50.102 52854 19 44 S 1045183726 0 1024 - - - RECEIVE
2026-04-21 17:51:03 DROP TCP 192.168.50.100 192.168.50.102 52854 17 44 S 1045183726 0 1024 - - - RECEIVE
2026-04-21 17:51:03 ALLOW UDP fe80::1175:e687:4aff:f10e ff02::1:2 546 547 0 - - - - - - - SEND
2026-04-21 17:51:03 DROP TCP 192.168.50.100 192.168.50.102 52856 17 44 S 1045314796 0 1024 - - - RECEIVE
```

COSA SIGNIFICA?
- Il firewall tiene traccia dei tentativi di connessione.
- È possibile individuare gli indirizzi IP degli aggressori.
- Le porte target mostrano attività di scansione.
- I log consentono la rilevazione anche senza accesso diretto.

Conclusione

I log di Windows sono fondamentali per la sicurezza informatica. Consentono di rilevare attività sospette, analizzare gli attacchi e supportare le attività di risposta agli incidenti.

Security Operation – Azioni Preventive

Questo documento esplora i concetti chiave di Business Continuity (BC), Disaster Recovery (DR) e ICT Readiness secondo lo standard ISO/IEC 27031, con l'obiettivo di comprendere come un'organizzazione possa garantire la resilienza operativa in caso di incidenti.

1. Business Continuity (BC)

La Business Continuity (BC) comprende le strategie e i processi che consentono a un'organizzazione di continuare a operare durante eventi critici. Si concentra sulla continuità delle operazioni aziendali piuttosto che sulla riparazione dei danni.

* **Esempi pratici:**
  * Sistemi ridondanti (server mirror)
  * Procedure manuali temporanee
  * Accesso remoto ai sistemi aziendali

2. Disaster Recovery (DR)

Il Disaster Recovery è l'insieme delle procedure tecniche per il ripristino dei sistemi IT e dei dati dopo un incidente. È una componente essenziale della Business Continuity.

* **Esempi pratici:**
  * Ripristino da backup
  * Utilizzo di snapshot
  * Failover su server secondari

Tabella comparativa BC vs DR

Aspetto	Business Continuity	Disaster Recovery
Obiettivo	Continuare le operazioni	Ripristinare sistemi IT
Focus	Processi aziendali	Infrastruttura IT
Tempistica	Durante incidente	Dopo incidente
Esempio	Lavoro remoto attivo	Ripristino server

4. ICT Readiness (ISO/IEC 27031)

L'ICT Readiness valuta la capacità dell'infrastruttura IT di garantire la continuità operativa. Include metriche essenziali come RTO e RPO.

- Definizioni chiave:
- RTO: Tempo massimo di ripristino
- RPO: Perdita dati accettabile

5. Caso Studio: Attacco Ransomware

In un attacco ransomware, i sistemi vengono cifrati e resi inaccessibili. La Business Continuity (BC) garantisce la continuità operativa dei servizi essenziali, mentre il Disaster Recovery (DR) permette il ripristino dei dati da backup sicuri, evitando così il pagamento del riscatto.

Insight Tecnico

L'integrazione tra BC e DR richiede test periodici, simulazioni di attacco e monitoraggio continuo. Senza test, anche le strategie più solide possono rivelarsi inefficaci.

Conclusione

BC e DR sono pilastri fondamentali della cybersecurity moderna. Un'organizzazione resiliente non solo previene gli attacchi, ma risponde e si riprende rapidamente.

Considerazioni personali

Questa attività mi ha fatto capire che la sicurezza non riguarda solo la prevenzione, ma anche la capacità di risposta e la resilienza. La distinzione tra Business Continuity e Disaster Recovery è cruciale per progettare sistemi robusti e affidabili.

EMANUELE CESTARI